

SEGURANÇA DA INFORMAÇÃO

INTRODUÇÃO

Dando continuidade à construção dos fundamentos teóricos e normativos que sustentam a segurança da informação, esta aula tem como propósito aprofundar a compreensão dos instrumentos de gestão, modelos de referência e *frameworks* internacionalmente consolidados que orientam as práticas organizacionais no tratamento seguro da informação.

A crescente sofisticação das ameaças digitais, associada à complexidade dos ambientes computacionais contemporâneos, impõe às organizações não apenas a adoção de tecnologias de proteção, mas sobretudo a implementação de sistemas estruturados de gestão da segurança. Nesse sentido, torna-se essencial compreender a função estratégica das políticas de segurança da informação, a aplicabilidade das normas internacionais como a ISO/IEC 27001, ISO/IEC 27002, ISO/IEC 15408 e NIST SP 800-30, bem como a integração com *frameworks* de governança e gestão como o CobiT e a biblioteca ITIL.

A aula propõe ainda uma análise crítica sobre o papel da segurança no desenvolvimento de *software*, destacando a importância de práticas como *security by design*, gestão de riscos e validação de conformidade. Também são discutidos os fundamentos do Sistema de Gestão de Segurança da Informação (SGSI), estruturado segundo o modelo de melhoria contínua PDCA, e a metodologia de avaliação de segurança com base no *Common Criteria* (ISO/IEC 15408).

Ao final, intenta-se a capacidade de identificar e aplicar os principais referenciais normativos e metodológicos da área, reconhecendo sua importância para a proteção de ativos informacionais e para o fortalecimento da governança corporativa, da conformidade regulatória e da resiliência organizacional.

TEMA 1 – VISÃO GERAL DAS NORMAS E PADRONIZAÇÃO

As normas de segurança da informação podem ser descritas a partir de uma política de segurança, isto é, um conjunto de regras e padrões que tem por objetivo garantir que informações valiosas para a instituição sejam protegidas de forma adequada, a fim de se respeitarem os pilares da segurança da informação. Ferreira e Araujo (2008, p. 36) definem assim políticas de segurança e sua elaboração:

A política de segurança define o conjunto de normas, métodos e procedimentos utilizados para a manutenção da segurança da

informação, devendo ser formalizada e divulgada a todos os usuários que fazem uso dos ativos de informação. Deve-se utilizar uma visão metódica, criteriosa e técnica em seu desenvolvimento e elaboração, de forma que possam ser sugeridas alterações na configuração de equipamentos, na escolha de tecnologias, na definição de responsabilidades e, por fim, na elaboração das políticas com o perfil da empresa e dos negócios que ela pratica.

Vale ressaltar que essas políticas devem expressar os interesses dos proprietários e dos acionistas, que têm por norma decidir os rumos dos negócios da instituição em relação ao uso das informações e tecnologias por todos os envolvidos que terão acesso a esses valores.

1.1 Considerações importantes para o desenvolvimento das políticas e normas de segurança

Ao se elaborar uma política ou normativa, é importante que os envolvidos nessa tarefa tenham em mente que esses documentos devem ser criados com intuito de prevenir a ocorrência de problemas com a segurança ou, caso ocorram falhas, evitar reincidências. Seu escopo precisa ser claro, abrangendo os responsáveis e os serviços atrelados ao documento, sendo possível a elaboração ou sugestão de criação de comitês de segurança (Albuquerque; Ribeiro, 2002). Isso, porém, não é o suficiente. Segundo Lyra (2017, p. 22) para a organização da segurança:

Não basta criar um novo departamento ou unidade administrativa e chamá-lo de Comitê Corporativo de Segurança da Informação para que tudo aconteça na organização. É preciso ter uma visão clara e abrangente de todas as etapas que compõem o desafio corporativo da segurança da informação bem como formalizar os processos que darão vida e dinamismo à gestão.

Para garantir a efetiva implementação dos atributos de segurança da informação, é essencial que a documentação organizacional esteja bem estruturada. A gestão interna deve estabelecer uma organização mínima capaz de gerenciar e aplicar políticas e normas de segurança. De acordo com o *National Institute of Standards and Technology* (NIST), segurança da informação diz respeito à proteção de informações e sistemas contra acessos, usos, divulgações, interrupções, modificações ou destruições não autorizadas (NIST, 2017, p. 17). O documento do instituto também apresenta oito elementos fundamentais que demonstram como requisitos e controles de segurança sustentam o desempenho eficaz da organização (NIST, 2017).

Peltier (2001, p. 79) adverte que “a segurança da informação deve ser reconhecida como uma função organizacional ampla”, exigindo envolvimento estratégico e transversal. Nesse sentido, Whitman e Mattord (2010) sustentam que a independência funcional da segurança da informação em relação à TI é essencial para preservar sua capacidade de fiscalizar, orientar e controlar com isenção os próprios sistemas que audita.

TEMA 2 – MODELOS DE ESPECIFICAÇÃO DA SEGURANÇA DA INFORMAÇÃO

Apesar dos avanços na área, a segurança da informação ainda é considerada um campo relativamente recente das ciências aplicadas, o que contribui para variações conceituais em termos fundamentais como ameaça, ativo, vulnerabilidade e ataque. Tais divergências terminológicas são comuns na literatura especializada. Para garantir coerência e precisão conceitual nesta aula, será adotada como referência principal a norma ISO/IEC 15408 (*Common Criteria*), embora se reconheça que documentos como a ISO/IEC 27000 e o NIST SP 800-30 também ofereçam definições próprias, conforme ilustrado na Tabela 1.

Tabela 1 – Quadro comparativo entre normas técnicas

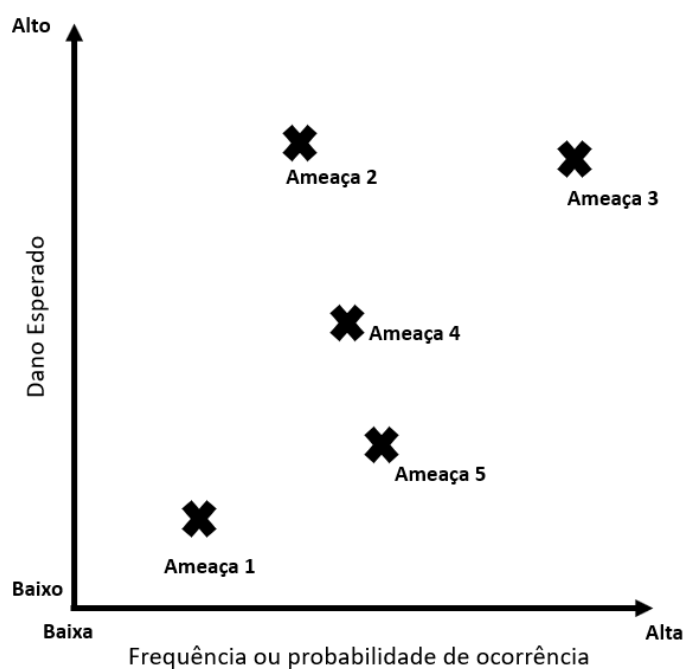
Termo	ISO/IEC 15408 (<i>Common Criteria</i>)	ISO/IEC 27000:2018	NIST SP 800-30 Rev.1
Ativo	Entidade associada ao sistema de TI que requer proteção	Algo que tem valor para a organização	Algo de valor para a organização, podendo incluir pessoas, sistemas, dados, <i>hardware</i> etc.
Ameaça	Causa potencial de um incidente indesejado que pode resultar em dano a um ativo	Causa potencial de um incidente indesejado que pode resultar em dano a um sistema ou organização	Qualquer circunstância ou evento com potencial de explorar vulnerabilidades e causar danos
Vulnerabilidade	Falha ou fraqueza em um ativo ou grupo de ativos que pode ser explorada por uma ameaça	Fragilidade de um ativo ou controle que pode ser explorada por uma ou mais ameaças	Fraqueza que pode ser explorada por uma ameaça para obter acesso não autorizado ou causar danos

Ataque	Ação de um agente de ameaça que tenta explorar uma vulnerabilidade para comprometer um ativo	Evento ou ação realizada por uma ameaça com o objetivo de comprometer a segurança da informação	Qualquer tentativa deliberada de explorar uma vulnerabilidade com o propósito de causar danos
---------------	--	---	---

Fonte: elaborado pelo autor, 2025.

No que se refere à segurança da informação, é muito complexo prevenir e prever todas as possibilidades de ataques, pois a gama de eventos é diversa – vale lembrar que alguns meios de ataque são impossíveis de prever neste momento. Logo, podemos dizer que um sistema estará seguro quanto mais defesas tiver contra os ataques mais previsíveis e com a maior perda esperada. A Figura 1 ilustra como se dá a interpretação de ataques sobre um sistema.

Figura 1 – Priorização de ameaças



Fonte: Albuquerque; Ribeiro, 2002, p. 4.

Na figura apresentada, dentro de normas, a primeira preocupação é com a ameaça 3. Já as ameaças 2, 4 e 5 são preocupantes e demandam atenção em seu comportamento, e, por fim, a 1 não representa perigo à organização.

2.1 Segurança em desenvolvimento de *software*

O desenvolvimento seguro de *software* exige atenção coordenada a três dimensões interdependentes: a segurança do ambiente de desenvolvimento, da aplicação e da percepção de segurança pelo cliente (Figura 2). A proteção do ambiente deve assegurar confidencialidade, integridade e disponibilidade de ativos como repositórios, sistemas de versionamento e equipes envolvidas (NIST, 2018; ISO/IEC, 2022a). Por sua vez, a aplicação deve ser projetada com base no princípio do *Security by Design*, evitando falhas, *backdoors* e vazamentos (Owasp, 2023; Howard; LeBlanc, 2003). Por fim, a garantia de segurança ao cliente deve ser demonstrada por auditorias e certificações formais (ISO/IEC, 2011, 2022b). Conforme destaca Schneier (2015), falhas em qualquer dessas dimensões comprometem a segurança, a confiança e o valor do produto.

Figura 2 – Preocupações em desenvolvimento de *software*



Crédito: Patrick Landal Athayde – Copilot/IA.

2.1.1 Segurança do ambiente de desenvolvimento

Um ambiente seguro para o trabalho é uma preocupação constante das diversas organizações, principalmente as que trabalham com objetos de valor. Logo, ele deve fornecer condições favoráveis ao desenvolvimento de um sistema seguro, conforme destaca Lyra (2017, p. 99):

[...] não é possível desenvolver uma aplicação segura em um ambiente não seguro. A garantia da segurança no ambiente de desenvolvimento de software depende da criticidade do mesmo. Quanto mais crítico, mais controles devem ser relacionados e vice-versa. As garantias em uma

fábrica de software devem ser, sem dúvida, muito maiores que em uma empresa de manufatura.

A segurança do ambiente de desenvolvimento de *software* requer práticas estruturadas que assegurem controle de acesso, integridade dos artefatos e confidencialidade das informações. O acesso deve ser restrito aos profissionais diretamente envolvidos, com permissões segmentadas conforme o princípio do privilégio mínimo. A documentação do código é vital para facilitar a manutenção por equipes externas.

A padronização do desenvolvimento favorece o alinhamento e a comunicação da equipe (Lyra, 2017), ao passo que o monitoramento contínuo previne vazamentos e acessos não autorizados. A gestão eficaz do ambiente deve garantir infraestrutura adequada, e a revisão periódica dos acessos é fundamental para evitar a acumulação indevida de privilégios, especialmente diante da rotatividade de pessoal (Chiavenato, 2002).

2.1.2 Segurança da aplicação desenvolvida

Durante o desenvolvimento de uma aplicação ou solução, algumas questões devem ser levantadas quanto à satisfação e à segurança do cliente: compreender sua necessidade de segurança, como transformar esse anseio em especificação do projeto, como implementar esse sistema de forma segura e, sobretudo, como realizar a validação do sistema para verificar se a solução atende aos requisitos propostos e às necessidades de segurança do cliente.

Há um vasto compêndio de condições e recomendações esperadas para a segurança da aplicação, que vão ao encontro das normas de boa programação (Albuquerque; Ribeiro, 2002) e visam a reduzir e eliminar erros e falhas da segurança. A seguir, estão elencados alguns elementos a serem seguidos como boas práticas de segurança para melhorar o sistema.

- **Tratar todas as variáveis de entrada como não confiáveis:** cada função deve validar se os valores recebidos estão dentro dos parâmetros aceitáveis e livres de caracteres inválidos ou configurações inadequadas antes de qualquer processamento.
- **Checar códigos de erro retornados por funções:** é fundamental realizar essa verificação, especialmente em chamadas à API do sistema operacional, para prevenir comportamentos inesperados.

- **Verificar o tamanho de *buffers* e *arrays*:** atenção especial deve ser dada ao uso de funções de biblioteca, pois a falta de validação pode provocar estouro de *buffer*.
- **Garantir comunicação eficiente entre os envolvidos no projeto:** a documentação do código é essencial para evitar falhas no desenvolvimento, promovendo alinhamento e clareza entre os membros da equipe.

Dessa forma, para que se possa produzir uma aplicação segura, é importante que o ambiente de desenvolvimento ofereça essa segurança, assim como se faz necessário uma boa especificação e realização de testes adequados ao que se solicita.

2.1.3 Garantia de segurança

A garantia de segurança em sistemas vai além do desenvolvimento seguro: envolve oferecer mecanismos que permitam ao cliente confiar na proteção do sistema entregue. Para isso, é recomendável possibilitar a validação da segurança por parte do cliente, seja por meio da verificação dos testes realizados, seja pela realização de testes independentes.

Albuquerque e Ribeiro (2002) destacam a importância de especificar claramente os requisitos de segurança, construir com base nessas especificações e realizar testes para assegurar sua conformidade. Complementarmente, Ferreira e Araújo (2008, p. 135-139) propõem diretrizes abrangentes que envolvem desde a aquisição até o descarte do sistema, defendendo uma política de segurança aplicada à administração, instalação, testes, uso e eliminação da solução desenvolvida. Segundo os autores:

Toda aquisição/utilização de hardware e software efetuada na organização deve ser orientada por uma **política clara, consistente e abrangente**, possibilitando à organização, resultados imediatos e impedindo qualquer penalidade pela lei de software em vigor. (Ferreira; Araújo, 2008, p. 135, grifo do original)

Dada a relevância estratégica da informação no cenário organizacional atual, é essencial tratá-la como um ativo valioso cuja proteção deve integrar as práticas de governança e gestão de riscos corporativos. A segurança da informação, portanto, exige uma abordagem integrada que contemple a proteção do ambiente de desenvolvimento, a segurança intrínseca da aplicação e a garantia de segurança percebida pelo cliente final. Quando esses três eixos são

articulados de forma coerente, sustentam um ecossistema digital confiável, resiliente e alinhado aos princípios de confidencialidade, integridade e disponibilidade (ISO/IEC, 2022a; NIST, 2018; Schneier, 2015).

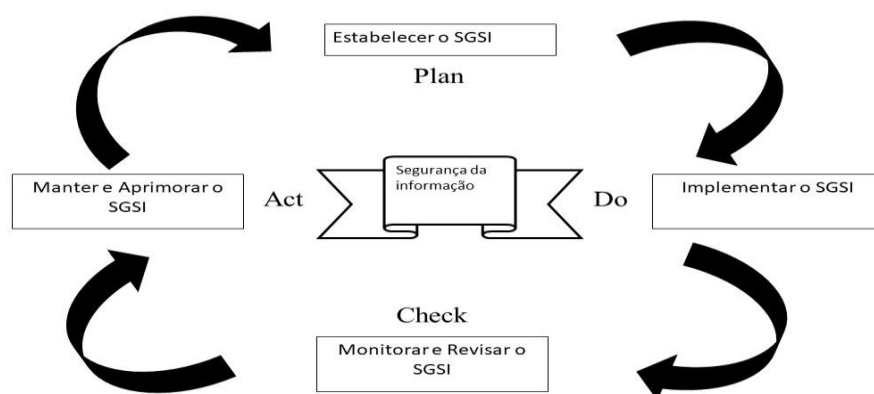
2.2 Sistema de gestão em segurança da informação

O Sistema de Gestão de Segurança da Informação (SGSI) – ou *Information Security Management System* (ISMS) – corresponde ao conjunto de ações, políticas, procedimentos e modelos destinados à mitigação de riscos associados à segurança da informação. Sua implementação deve considerar os ativos protegidos, o gerenciamento de riscos e os controles adotados (Ferreira; Araujo, 2008, p. 54).

A construção do SGSI costuma seguir o ciclo *Plan-Do-Check-Act* (PDCA), metodologia reconhecida por sua eficácia na resolução de problemas e promoção da melhoria contínua em diversos contextos organizacionais, desde gestão de projetos até governança corporativa. Esse ciclo apresenta como principal vantagem a flexibilidade metodológica, pois é aplicável a diferentes setores e portes organizacionais, o que o torna uma ferramenta transversal (Paladini, 2012).

O foco do PDCA na melhoria contínua promove uma cultura de excelência e inovação incremental, alinhando-se aos princípios da gestão da qualidade total (TQM) e normas como a ISO 9001:2015. A Figura 3 ilustra como realizar essa aplicação.

Figura 3 – Organização e implantação de SGSI



Fonte: Elaborado com base em Ferreira; Araujo, 2008.

Entretanto, sua implementação enfrenta desafios, como a resistência à mudança, a exigência de recursos e competências específicas e a necessidade de disciplina para manter a continuidade do ciclo. Tais dificuldades requerem uma cultura organizacional favorável, apoio da liderança e mecanismos institucionais de governança. Quando bem aplicado, o PDCA torna-se um agente de transformação organizacional e de aprimoramento contínuo dos processos.

TEMA 3 – COMMON CRITERIA FOR TECHNOLOGY SECURITY EVALUATION (ISO/IEC 15408)

A norma ISO/IEC 15408, conhecida como *Common Criteria* (CC), estabelece um referencial técnico para especificar e avaliar requisitos de segurança em produtos e sistemas de TI (ISO/IEC, 2009). Seu objetivo é padronizar a definição de atributos de segurança por meio do *Security Target* (ST), documento que detalha objetivos e mecanismos de proteção de uma solução específica.

Para medir a confiança na segurança, o CC utiliza sete níveis de garantia de avaliação (*evaluation assurance levels* – EALs), que representam um rigor metodológico crescente. O nível máximo (EAL7) se destina a cenários de altíssima criticidade, como militares e governamentais, já o EAL3 é geralmente considerado um balanço adequado entre custo e segurança para a maioria dos sistemas corporativos. A Tabela 2 detalha cada um desses níveis.

Tabela 2 – Níveis de garantia de avaliação (EAL)

Nível EAL	Descrição	Objetivo Principal	Aplicação Comum
EAL1	Funcionalmente testado	Confirmação de que as funções de segurança estão presentes e foram testadas.	Avaliação rápida e econômica de produtos genéricos.
EAL2	Testado estruturalmente	Requer uma análise da arquitetura do produto e testes independentes.	Produtos de uso geral com necessidades moderadas.
EAL3	Testado metodicamente e verificado	Exige revisão de desenvolvimento, testes formais e controle de configuração.	Aplicações corporativas que exigem maior confiança.
EAL4	Projetado, testado e revisado metodicamente	Oferece uma análise mais detalhada, testes independentes e análise de vulnerabilidades.	Produtos comerciais de missão crítica.
EAL5	Projetado semiestruturalmente e testado	Exige documentação mais completa, testes mais rigorosos e medidas para proteger o projeto.	Ambientes sensíveis e sistemas militares.
EAL6	Projetado estruturalmente para alta segurança	Avaliação profunda, análise completa de segurança e mitigação de ataques sofisticados.	Sistemas financeiros ou militares altamente críticos.
EAL7	Projetado formalmente e testado	Nível máximo: exige especificação formal, desenvolvimento controlado, testes formais e validação exaustiva.	Infraestruturas críticas com altíssimo risco.

Fonte: Elaborado com base em Albuquerque; Ribeiro, 2002.

Conforme ressaltam Stallings e Brown (2018, p. 459), "a estrutura de níveis de garantia do Common Criteria permite comparar a segurança de produtos distintos com base em critérios objetivos, servindo como um guia fundamental para decisões de aquisição e desenvolvimento seguro de sistemas de informação".

TEMA 4 – CONTROL OBJECTIVES FOR INFORMATION AND RELATED TECHNOLOGIES (COBIT)

Control Objectives for Information and Related Technology (CobiT) é um *framework* desenvolvido pela *Information Systems Audit and Control Association* (Isaca), que fornece princípios e práticas para alinhar a tecnologia da informação (TI) aos objetivos de negócio, garantindo controle e conformidade. Considerado uma das melhores práticas mundiais para controles de TI, especialmente no setor financeiro, sua abrangência é demonstrada pelo fato de o *Federal Reserve* dos Estados Unidos tê-lo adotado como referência para a auditoria de sistemas de informação do sistema bancário americano, conforme destacam Ferreira e Araujo (2008, p. 57).

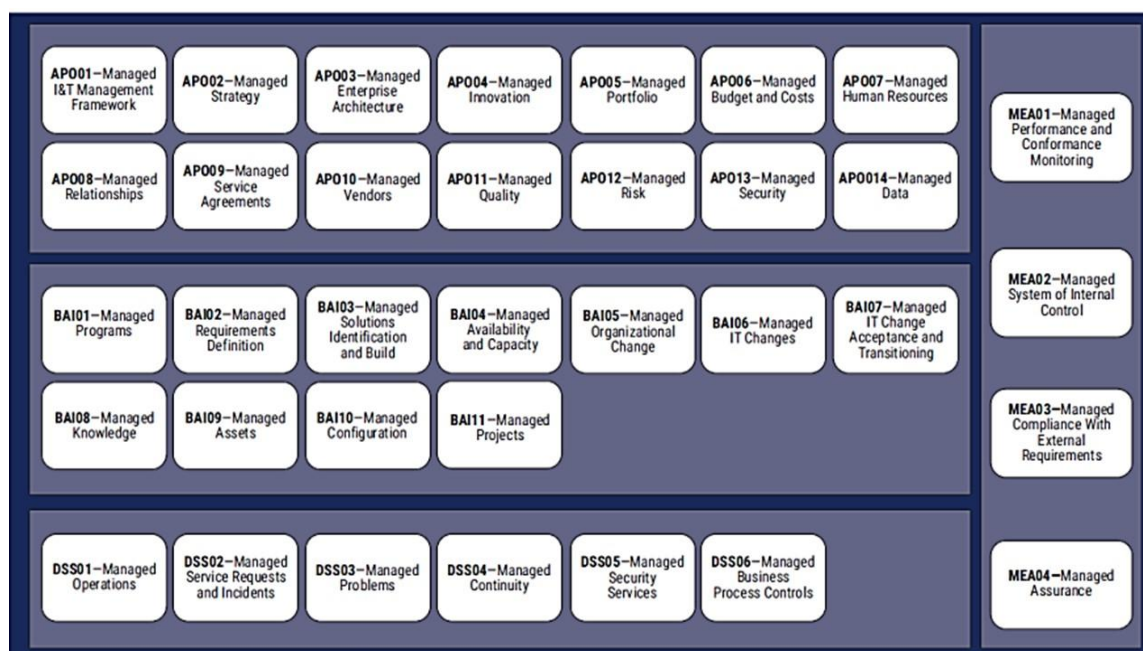
4.1 Divisão da estrutura

O CobiT é organizado em quatro domínios principais, que são subdivididos em 34 processos que determinam os objetivos de controle para a manutenção de uma estrutura de controles que permitam à instituição atingir seus objetivos de maneira confiável. Os quatro domínios são:

- Alinhar, Planejar e Organizar (*Align, Plan, Organize* – APO);
- Construir, Adquirir e Implementar (*Build, Acquire, Implement* – BAI);
- Entrega, Serviço e Suporte (*Delivery, Service, Support* – DSS);
- Monitoramento, Avaliação e Análise (*Monitor, Evaluate, Assess* – MEA).

A Figura 4 mostra como esses domínios e os respectivos processos estão relacionados.

Figura 4 – Domínios e processos



Fonte: Isaca, 2019.

4.1.1 Alinhar, Planejar e Organizar

O domínio **Alinhar, Planejar e Organizar (APO)** constitui um pilar estratégico da gestão de TI, promovendo sua integração com os objetivos organizacionais (Isaca, 2019). Abrange desde a formulação da estratégia até sua execução, garantindo que a TI atue como habilitadora de valor. Para isso, exige planejamento estruturado, comunicação eficaz e gestão colaborativa entre liderança, gestores e usuários finais.

A eficácia do APO está vinculada à capacidade de responder a questionamentos críticos que incluem: de que modo a TI suporta diretamente as metas de negócio? Como os investimentos em TI maximizam retorno e eficiência? Quais mecanismos asseguram a coerência entre decisões tecnológicas e operacionais?

4.1.2 Construir, Adquirir e Implementar

O domínio **Construir, Adquirir e Implementar** (em inglês, BAI) concentra-se na criação, aquisição e implementação de soluções tecnológicas alinhadas às demandas organizacionais (Isaca, 2019). Sua principal função é garantir que os projetos de TI sejam entregues com qualidade, dentro do prazo estabelecido e

em conformidade com os requisitos definidos, assegurando ainda o controle adequado em todo o ciclo de vida.

Esse domínio abrange processos essenciais como: gestão de projetos e mudanças; administração de ativos e configurações; definição e validação de requisitos; e transição de serviços para produção. Além disso, promove a integração entre desenvolvimento e operações, incorporando práticas modernas como *DevOps* e gestão do conhecimento para otimizar a eficiência e segurança das implantações. As questões centrais que o orientam domínio incluem:

- alinhamento estratégico: as soluções atendem aos requisitos funcionais e estratégicos do negócio?
- governança de projetos: os projetos seguem metodologias formais para mitigar riscos e desvios?
- gestão de mudanças: os processos de alteração são controlados e preservam a continuidade dos serviços?
- transição para produção: a implantação ocorre de forma estruturada e segura?

Conforme destacado pela Isaca (2012), o BAI desempenha papel fundamental ao assegurar que as soluções de TI sejam implementadas com sucesso e prontas para suportar as operações de negócio.

4.1.3 Entrega, Serviço e Suporte

O domínio **Entrega, Serviço e Suporte** (em inglês, DSS) foca entrega eficaz dos serviços de TI, suporte ao usuário e manutenção da operação contínua e segura dos sistemas. Visa a garantir disponibilidade, confiabilidade e proteção dos serviços, além de assegurar respostas eficientes a incidentes, requisições e problemas operacionais. Também abrange controles de segurança, gestão da continuidade de serviços e execução operacional, fornecendo diretrizes para a estabilidade e eficiência da infraestrutura tecnológica.

Conforme observado por Stallings e Brown (2018), a operação segura e contínua de serviços de TI exige não apenas tecnologia robusta, mas também práticas de gestão bem definidas e orientadas à qualidade de serviço.

4.1.4 Monitoramento, Avaliação e Análise

O domínio **Monitoramento, Avaliação e Análise** (em inglês, MEA) trata da avaliação contínua do desempenho, da conformidade e dos controles internos de TI. O objetivo é promover transparência, auditoria e responsabilização, garantindo o alinhamento das ações de TI com políticas, normas e exigências legais. Engloba o monitoramento da performance organizacional, a avaliação da eficácia dos controles internos e a verificação da conformidade com requisitos internos e externos.

Entre as perguntas essenciais que o MEA busca responder, destacam-se:

- Os processos de TI estão sendo monitorados quanto ao desempenho e à conformidade?
- Os controles internos são eficazes e devidamente auditados?
- A organização está em conformidade com os requisitos legais, regulatórios e contratuais?
- Os relatórios de desempenho e riscos de TI são comunicados aos *stakeholders* de forma clara e tempestiva?

De acordo com ITGI (2007, p. 56), a função de monitoramento e avaliação permite que “as decisões baseadas em TI sejam fundamentadas em evidências, assegurando eficácia, conformidade e controle”.

TEMA 5 – INFORMATION TECHNOLOGY INFRASTRUCTURE LIBRARY (ITIL)

Ferreira e Araujo (2008, p. 65) afirmam que “as organizações estão cada vez mais dependentes da Tecnologia da Informação para alcançar seus objetivos, o que demanda serviços de TI de alta qualidade e alinhados ao mercado”. Essa crescente relevância exige que os profissionais da área compreendam o modo pelo qual aspectos como qualidade, quantidade e disponibilidade da infraestrutura impactam diretamente as atividades organizacionais.

Nesse sentido, um grupo de organizações industriais e governamentais do Reino Unido se organizou no final dos anos de 1980 para elaborar um documento norteador para gestão de serviços em TI, o que levou à constituição do ITIL, acrônimo inglês para *Information Technology Infrastructure Library* ou Biblioteca para Infraestrutura de serviços de TI, inicialmente composto por 60 livros, como um conjunto de práticas em TI.

A proposta tem por finalidade oferecer uma estratégia que possa ser aplicada em qualquer tipo de organização, considerando a gestão em serviços de TI como um conjunto de processos fortemente interligados. Os objetivos da gestão em serviços de TI devem levar em conta três pilares: pessoal envolvido, processos e tecnologia. Devido à sua preocupação e foco na excelência e qualidade dos serviços, hoje o ITIL pode ser entendido como um protocolo padrão.

Desde o início de sua proposição no final da década de 1980, a proposta ITIL foi disponibilizada sem qualquer restrição, ou seja, toda organização pode adotar o protocolo e a estrutura descritos no documento. Isso facilita a utilização por uma grande quantidade de organizações, tanto entidades privadas quanto órgãos públicos.

Importante ressaltar que os processos indicados pela ITIL são aplicados como base de conformidade para as normas BS 15000 (*British Standard for IT Service Management*) e ISO/IEC 20000.

REFERÊNCIAS

ABNT – Associação Brasileira de Normas Técnicas. **NBR ISO/IEC 27001:2013** – Tecnologia da informação – Técnicas de segurança – Sistemas de gestão da segurança da informação – Requisitos. Rio de Janeiro: ABNT, 2013.

ALBUQUERQUE, R.; RIBEIRO, B. **Segurança no desenvolvimento de software**: como desenvolver sistemas seguros e avaliar a segurança de aplicações desenvolvidas com base na ISO 15.408. Rio de Janeiro: Campus, 2002.

AXELOS. **ITIL Foundation**: ITIL 4 Edition. London: The Stationery Office, 2019. Disponível em: <<https://www.axelos.com/store/book/itil-foundation-itil-4-edition>>. Acesso em: 14 jul. 2025.

CHIAVENATO, I. **Teoria geral da administração**. Rio de Janeiro: Elsevier Brasil, 2002.

FERREIRA, F. N. F.; ARAUJO, M. T. **Política de Segurança da Informação** – Guia prático para elaboração e implementação. Rio de Janeiro: Ciência Moderna, 2008.

HOWARD, M.; LEBLANC, D. **Writing Secure Code**. 2. ed. Redmond: Microsoft Press, 2003.

ISACA – Information Systems Audit and Control Association. **COBIT 5**: um framework para governança e gestão de TI corporativa. Rolling Meadows: Isaca, 2012.

ISACA – Information Systems Audit and Control Association. **COBIT 2019 Framework**: Governance and Management Objectives. [S.I.]: Isaca, 2019.

ISO – The International Organization for Standardization; IEC – The International Electrotechnical Commission. **ISO/IEC 27002:2022**. Information security, cybersecurity and privacy protection – Information security controls. Geneva: ISO/IEC, 2022a.

ISO – The International Organization for Standardization; IEC – The International Electrotechnical Commission. **ISO/IEC 15408**. Common Criteria for Information Technology Security Evaluation. Geneva: ISO/IEC, 2022b. Disponível em: <<https://www.commoncriteriaportal.org>>. Acesso em: 14 jul. 2025.

ISO – The International Organization for Standardization; IEC – The International Electrotechnical Commission. **ISO/IEC 27034-1:2011**. Application Security – Part 1: Overview and Concepts. Geneva: ISO/IEC, 2011. Disponível em: <<https://www.iso.org/standard/44378.html>>. Acesso em: 14 jul. 2025.

ITGI – IT Governance Institute. **Board Briefing on IT Governance**. 2. ed. Rolling Meadows: ITGI, 2007.

LYRA, M. R. **Segurança e auditoria em sistemas de informação**. Rio de Janeiro: Ciência Moderna, 2017.

NIST – National Institute of Standards and Technology. **An introduction to information security**: NIST Special Publication 800-12 Revision 1. Gaithersburg: NIST, 2017. Disponível em: <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-12r1.pdf>>. Acesso em: 14 jul. 2025.

NIST – National Institute of Standards and Technology. **Framework for Improving Critical Infrastructure Cybersecurity**. Version 1.1. Gaithersburg: NIST, 2018. Disponível em: <<https://www.nist.gov/cyberframework>>. Acesso em: 14 jul. 2025.

OWASP – Open Web Application Security Project. **Secure Software Development Lifecycle (S-SDLC)**. 2023. Disponível em: <<https://owasp.org/www-project-secure-software-development-life-cycle/>>. Acesso em: 14 jul. 2025.

PALADINI, E. P. **Gestão da qualidade** – teoria e prática. 3. ed. São Paulo: Atlas, 2012.

PELTIER, T. R. **Information Security Policies, Procedures, and Standards**: guidelines for effective information security management. Boca Raton: Auerbach Publications, 2001.

SCHNEIER, B. **Data and Goliath**: The Hidden Battles to Collect Your Data and Control Your World. W. W. New York: Norton & Company, 2015.

STALLINGS, W.; BROWN, L. **Computer security** – Principles and practice. New York: Pearson, 2018.

WHITMAN, M. E.; MATTORD, H. J. **Principles of Information Security**. 4. ed. Boston: Cengage Learning, 2010.